

GESTIÓN DE RIESGOS DE IA

GOBERNANZA Y SEGURIDAD

Manual de Gestor Práctico y Analista Junior

Qué hace este manual: Explica cómo aprobar, mapear, probar, asegurar, monitorizar y demostrar el uso responsable de la IA. Cubre ML tradicional, IA generativa, RAG, agentes, herramientas, NIST AI RMF, estándares ISO, riesgos OWASP, CSA AICM, decisiones de gestores, trabajo de analistas y laboratorios seguros.

Alberto (Al) Leiva

Primera edición • julio de 2026

Prefacio

La inteligencia artificial puede ayudar a las personas, crear contenido, clasificar decisiones, detectar patrones y tomar medidas. También puede ser incorrecto, sesgado, manipulado, excesivamente poderoso, difícil de explicar o utilizado más allá de su propósito aprobado. Un buen gobierno ayuda a una organización a obtener valor mientras protege a las personas, la información, las operaciones y la confianza.

Este manual utiliza un lenguaje sencillo y se centra en trabajos prácticos. No es asesoramiento legal, ni una guía de certificación, ni una promesa de que un sistema es seguro. Las leyes, estándares, comportamientos de modelos, amenazas y características de los proveedores cambian rápidamente. Confirma fuentes autorizadas actuales e involucra a profesionales cualificados en derecho, privacidad, seguridad, ciencia de datos, derechos humanos, seguridad, contratación, auditoría y negocios para tomar decisiones reales.

Nota de información actualizada: Verificada el 14 de julio de 2026. NIST AI RMF 1.0 sigue siendo el marco publicado, pero NIST afirma que está en revisión. NIST AI 600-1 sigue siendo el Perfil de IA Generativa. CSA AICM v1.1 se lanzó en junio de 2026. Las obligaciones de la Ley de IA de la UE se aplican de forma progresiva, y los cambios de calendario propuestos no son ley definitiva a menos que se adopten; verifica el estado con fuentes oficiales y abogados.

Cómo usar este manual

- Managers: empieza con los capítulos 1–10, 22–28, y luego usa los registros de decisiones del capítulo 30.
- Analistas junior: estudian en orden, gestionan solo laboratorios autorizados y construyen el portafolio en el Capítulo 29.
- Desarrolladores y equipos de datos: centrados en los capítulos 10–23 y las herramientas de pruebas del capítulo 26.
- GRC, equipos de privacidad, legales y auditoría: centrarse en los capítulos 2–9 y 20–25.
- Registra el sistema exacto, modelo, versión, datos, uso, usuarios, geografía, impacto, evidencia, limitaciones y decisiones para cada evaluación.

Índice

Este archivo contiene un índice auténtico de Word, además de una guía permanente de capítulos numerada por página.

Prefacio	2
Cómo usar este manual	2
Índice	3
Guía de capítulos	7
1. Fundamentos de IA y uso fiable	8
1.1 Características fiables	8
2. Gobernanza, Normas y Panorama Legal	9
2.1 Registro legal y de obligaciones	9
3. Núcleo RMF de NIST AI	10
4. GOBERNAR: Cultura, Responsabilidad y Política	11
4.1 Estructura de gobernanza	11
5. MAPA: Contexto, Personas e Impacto	13
5.1 Registro de contexto	13
6. MEDIDA: Pruebas y análisis de riesgos	15
6.1 Plan de medición	15
7. GESTIONAR: Tratamiento, Despliegue y Mejora	16
7.1 Puerta de despliegue	16
8. Perfil de IA generativa del NIST	17
9. ISO/IEC 42001 e ISO/IEC 23894	18
9.1 Certificaciones y advertencias sobre derechos de autor	18
10. Inventario, casos de uso y ciclo de vida de la IA	19
10.1 Controles del ciclo de vida	19
11. Gobernanza de Datos y Seguridad de los Datos	20
11.1 Cadena de control de datos	20
12. Gobernanza de modelos y riesgo de modelo	21
12.1 Preguntas de validación	21
13. Modelos de Fundación y Terceros	22
13.1 Concentración y riesgo en la cadena de valor	22
14. Modelado de amenazas de seguridad por IA	23
14.1 Método de modelos de amenaza	23

15. Top 10 OWASP para solicitudes LLM 2025	24
15.1 Cómo utiliza un analista la lista.....	24
16. Seguridad de IA Agéntica.....	25
17. Seguridad de Generación Aumentada por Recuperación	26
Controles RAG 17.1	26
18. Seguridad de Prompts, Interfaz y Salida	27
18.1 Ejemplos de manejo de salida.....	27
19. Identidad, herramientas, APIs y MCP	28
19.1 Seguridad MCP	28
20. Privacidad, Propiedad Intelectual y Registros.....	29
20.1 Privacidad y evaluación de registros.....	29
20.2 Propiedad intelectual	29
21. Equidad, transparencia, explicabilidad y supervisión humana	30
21.1 Evitar errores comunes.....	30
22. Evaluación, Selección en Equipo Rojo y Aceptación	31
22.1 Reglas de enfrentamiento del equipo rojo.....	31
23. Supervisión, Incidentes, Cambio y Jubilación.....	32
23.1 Respuesta a incidentes de IA	32
24. Aseguramiento, evidencia, pruebas y métricas	33
24.1 Método de prueba de control	33
25. Matriz de controles de IA de CSA v1.1	34
25.1 Uso práctico	34
26. Herramientas de garantía y seguridad de IA de código abierto.....	35
26.1 Garak.....	35
26.2 Promptfoo.....	35
26.3 Giskard	36
26.4 PyRIT	36
26.5 Inspeccionar IA	36
26.6 Caja de herramientas de robustez adversarial	36
26.7 LLM Guard	36
26.8 Presidio	37
IA de las barreras de seguridad 26.9	37
26.10 Evaluaciones de OpenAI	37
26.11 Langfuse	37

26.12 MLflow	38
26.13 Evidentemente	38
26.14 Deepchecks	38
26.15 ModelScan	38
26.16 Gitleaks	39
26.17 Trivy	39
26.18 MITRE ATLAS	39
27. Manual de Gobernanza de IA para el Gestor	40
27.1 Ritmo de funcionamiento	40
27.2 Preguntas que los líderes deben responder	40
28. Guía de carrera para analista junior de riesgos y seguridad en IA	41
28.1 Puestos de nivel inicial	41
28.2 Trabajo diario	41
28.3 Pruebas de currículum	42
29. Laboratorio ficticio, plan de treinta días y entrevistas	43
29.1 Laboratorio de portafolio	43
29.2 Plan de treinta días	43
29.3 ¿Qué es el RMF de IA del NIST?	44
29.4 ¿Riesgo de modelo frente a riesgo de sistema?	44
29.5 ¿Qué es la inyección rápida?	44
29.6 ¿Cómo evalúas un LLM?	44
29.7 ¿Qué es RAG?	44
29.8 ¿Por qué es difícil la supervisión humana?	44
29.9 ¿Qué es un inventario de IA?	44
29.10 ¿Cómo demuestran las herramientas el cumplimiento?	44
29.11 ¿Cómo se informa de un hallazgo?	44
29.12 ¿Qué hace a un buen analista junior?	45
30. Plantillas, glosario, índice y referencias	46
Inventario de casos de uso de IA 30.1	46
30.2 Evaluación del impacto y riesgo de la IA	46
30.3 Trabajo de evaluación de IA	46
30.4 Registro de incidentes y cambios de IA	46
30.5 Glosario	47
30.6 Índice temático	47

30.7 Referencias oficiales	48
----------------------------------	----

Guía de capítulos

Capítulo	Título	Empieza en la página
1	Fundamentos de IA y uso fiable	5
2	Gobernanza, Normas y Panorama Legal	6
3	Núcleo RMF de NIST AI	7
4	GOBERNAR: Cultura, Responsabilidad y Política	8
5	MAPA: Contexto, Personas e Impacto	10
6	MEDIDA: Pruebas y análisis de riesgos	12
7	GESTIONAR: Tratamiento, Despliegue y Mejora	13
8	Perfil de IA Generativa del NIST	14
9	ISO/IEC 42001 e ISO/IEC 23894	15
10	Inventario, casos de uso y ciclo de vida de la IA	16
11	Gobernanza de Datos y Seguridad de Datos	17
12	Gobernanza del modelo y riesgo del modelo	18
13	Modelos de Fundación y Terceros	19
14	Modelado de amenazas de seguridad por IA	20
15	Top 10 de OWASP para aplicaciones LLM 2025	21
16	Seguridad de IA Agentic	22
17	Seguridad de Generación Aumentada por Recuperación	23
18	Seguridad de prompts, interfaz y salida	24
19	Identidad, herramientas, APIs y MCP	25
20	Privacidad, Propiedad Intelectual y Registros	26
21	Equidad, transparencia, aplicabilidad y supervisión humana	27
22	Evaluación, Red Teaming y Aceptación	28
23	Supervisión, Incidentes, Cambio y Jubilación	29
24	Aseguramiento, evidencia, pruebas y métricas	31
25	Matriz de controles de IA de CSA v1.1	32
26	Herramientas de garantía y seguridad de IA de código abierto	33
27	Manual de Gobernanza de IA para el Gestor	39
28	Guía de carrera para Analista Junior de Riesgos y Seguridad en IA	40
29	Laboratorio ficticio, plan de treinta días y entrevistas	42
30	Plantillas, glosario, índice y referencias	45

1. Fundamentos de IA y uso fiable

La IA fiable depende del sistema completo, sus personas, propósito, datos, modelo, interfaces, controles y efectos reales.



AI risk management follows the system from idea through retirement

Figura 1. Ciclo de vida de los sistemas de IA

Concepto	Significado sencillo	Pregunta de analista
Sistema de IA	Personas, datos, modelos, software, infraestructura, reglas y procesos utilizados para un resultado	¿Cuál es el límite completo?
Aprendizaje automático	El software aprende patrones a partir de datos en lugar de solo reglas fijas	¿Qué datos y métricas apoyan este comportamiento?
IA generativa	Un modelo produce texto, imágenes, audio, video, código u otro contenido	¿Qué se puede inventar, filtrar o abusar?
IA agente	Un sistema planifica y utiliza herramientas para perseguir objetivos con cierta autonomía	¿Qué autoridad puede ejercer?
Fiabilidad	Pruebas de que se abordan características como la validez, seguridad, privacidad, equidad, transparencia y rendición de cuentas	¿Qué afirmación, umbral, prueba y propietario lo respaldan?

1.1 Características fiables

- Válido y fiable: funciona para el propósito y las condiciones definidas.
- Seguro: se previene o reduce daños físicos, financieros, legales, emocionales u operativos inaceptables.
- Seguro y resiliente: resiste ataques, mal uso, fracasos y interrupciones, y puede recuperarse.
- Responsable y transparente: se pueden examinar decisiones, propietarios, límites y pruebas.
- Explicable e interpretable: las personas reciben razones útiles apropiadas a la decisión.
- Privacidad mejorada y justa: los datos y resultados se gestionan legalmente y se evalúa el sesgo perjudicial.

2. Gobernanza, Normas y Panorama Legal

La gobernanza conecta marcos voluntarios, sistemas de gestión, prácticas técnicas, contratos y la legislación aplicable.

Fuente	Uso	Límite importante
NIST AI RMF 1.0	Marco voluntario de riesgos organizado como Gobernar, Mapear, Medir, Gestionar	Publicado en 2023; El NIST dice que la revisión está en marcha
NIST AI 600-1	Perfil de riesgo y acciones de IA generativa	Un perfil, no una certificación
ISO/IEC 42001:2023	Requisitos del sistema de gestión de IA	Estándar protegido por derechos de autor; Es importante el alcance de la certificación
ISO/IEC 23894:2023	Guía para la gestión de riesgos de IA	Adaptación a la organización y al contexto
Ley de IA de la UE	Obligaciones legales basadas en el riesgo para roles y usos cubiertos	La aplicación es por fases; Hechos y control actual de la ley
ATLAS DE LA VESPA / MITRE	Riesgos de seguridad, técnicas, defensas e ideas de pruebas	No un programa de cumplimiento completo
CSA AICM v1.1	Objetivos de control de IA y mapeo de garantía	Utilizar artefacto actual y alcance aplicable

2.1 Registro legal y de obligaciones

- Identificar jurisdicciones, sectores, clientes, contratos, normas laborales, deberes del consumidor, derecho de privacidad, propiedad intelectual, registros, accesibilidad, discriminación, seguridad de productos y requisitos de ciberseguridad.
- Clasificar el rol organizacional: proveedor/desarrollador, desplegador/operador, importador, distribuidor, usuario, controlador/procesador de datos, u otro rol definido por ley u contrato.
- Registrar el uso exacto, personas afectadas, características prohibidas o de alto impacto, aviso, consentimiento u otra autoridad, revisión humana, derechos, informes, retención y obligaciones de proveedores.
- Trata los resúmenes regulatorios como ayudas para el cribado. Obtén asesoramiento cualificado sobre la aplicabilidad y los plazos.

3. Núcleo RMF de NIST AI

El núcleo NIST AI RMF utiliza cuatro funciones conectadas para gestionar los riesgos de la IA para personas, organizaciones y sociedad.



NIST AI RMF functions work continuously, not as a one-time checklist

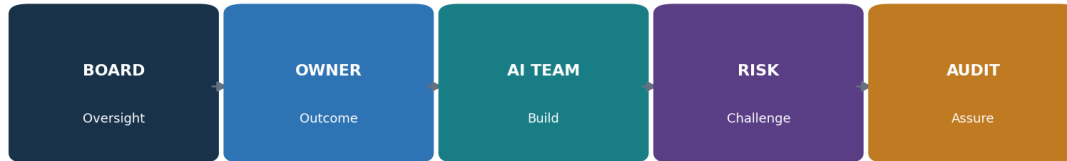
Figura 2. Núcleo RMF de NIST AI

Función	Propósito	Evidencia típica
GOBERNA	Políticas, roles, cultura, responsabilidad, tolerancia al riesgo, proveedores y mejora continua	Carta, política, RACI, formación, inventario, excepciones, actas
MAPA	Propósito, contexto, personas, impactos, dependencias y riesgos	Mapa del sistema, caso de uso, partes interesadas, evaluación de impacto, modelo de amenazas
MEDIDA	Métodos, pruebas, métricas, incertidumbre, limitaciones y revisión independiente	Plan de pruebas, conjuntos de datos, resultados, confianza, informe del equipo rojo, validación
GESTIONAR	Priorizar, tratar, aceptar, desplegar, monitorizar, responder y retirarse	Registro de riesgos, aprobaciones, condiciones, monitorización, registros de incidentes/cambios/jubilación

No use el RMF como casilla de verificación: una categoría o subcategoría solo se vuelve útil después de vincularla a un sistema propio, un riesgo, una acción, evidencia, un resultado, una decisión y una fecha de revisión.

4. GOBERNAR: Cultura, Responsabilidad y Política

GOVERN establece quién puede decidir, qué normas se aplican y cómo las preocupaciones llegan a los líderes responsables.



Clear decision rights prevent accountability gaps

Figura 3. Roles de gobernanza de la IA

4.1 Estructura de gobernanza

- Consejo o órgano de gobierno: supervisar el riesgo material y el desempeño de la gestión.
- Patrocinador ejecutivo: establecer la dirección, los recursos, el apetito por el riesgo y la escalada.
- Propietario del negocio: propósito, beneficio, proceso afectado, supervisión humana y resultado.
- IA/propietario del modelo: selección, configuración, evaluación, versiones y limitaciones del modelo.
- Propietario de los datos: autorizar las fuentes, la calidad, el acceso, el uso, la retención y la eliminación.
- Expertos en seguridad, privacidad, legal, cumplimiento, recursos humanos, adquisiciones, accesibilidad y dominio: revisen sus riesgos.
- Riesgo o validación independiente: cuestionar la evidencia y las decisiones a un nivel acorde con el impacto.
- Auditoría interna: evalúa de forma independiente la gobernanza y el control de la operación sin convertirse en el propietario.

• Área de política	• Decisión mínima
Uso aceptable	Usos y datos aprobados, restringidos y prohibidos
Escalonamiento de riesgo	Factores de impacto, umbrales, revisiones requeridas y autoridad
Desarrollo/adquisición	Ciclo de vida seguro, pruebas de proveedores, pruebas, aprobación y cambio
Supervisión humana	Competencia, autoridad, carga de trabajo, información, anulación y escalada del revisor
Excepciones	Riesgo, controles de compensación, aprobación, expiración, monitorización y cierre

● Área de política	● Decisión mínima
Preocupaciones	Speak-up, no represalias, investigación, protección y denuncia

5. MAPA: Contexto, Personas e Impacto

MAP convierte la descripción de un modelo en una imagen comprensible del propósito, las personas, el contexto y el impacto.



Assess the complete sociotechnical system—not only the model

Figura 4. Mapa completo del sistema de IA

5.1 Registro de contexto

- Necesidad empresarial, beneficio previsto, medida de éxito, propietario, usuarios y usos prohibidos.
- Personas y comunidades afectadas, incluyendo personas que quizá nunca interactúen directamente con el sistema.
- Decisión o contenido producido, grado de automatización, consecuencias, alternativas, contestabilidad y autoridad humana.
- Fuentes de datos, linaje, derechos, representatividad, atributos sensibles, proxies y calidad.
- Modelo, proveedor, versión, configuración, prompts, recuperación, ajuste fino, herramientas, integraciones, infraestructura y dependencias.
- Condiciones de despliegue, geografía, idioma, accesibilidad, cultura, sensibilidad temporal, escala y uso indebido razonablemente previsible.
- Modos de fallo, actores amenazantes, daños, beneficios, incertidumbre, controles existentes y monitorización.

Factor de impacto	Ejemplo de preocupación menor	Ejemplo de mayor preocupación
Decisión	Redacción de texto interno	Elegibilidad, empleo, crédito, cuidado, seguridad o decisión legal
Personas	Personal formado con revisión	Personas públicas o vulnerables con opciones limitadas
Autonomía	Solo una sugerencia	Actúa a través de cuentas, dinero, sistemas o dispositivos físicos
Escala	Pequeño piloto reversible	Efecto grande, persistente y difícil de revertir
Datos	Sintético o público	Datos sensibles, biométricos, confidenciales o de niños
Transparencia	Claramente revelado y discutible	Uso oculto o atractivo débil

Factor de impacto	Ejemplo de preocupación menor	Ejemplo de mayor preocupación
Fracaso	Pequeñas molestias	Daños materiales financieros, de salud, derechos, seguridad o protección

6. MEDIDA: Pruebas y análisis de riesgos

MEASURE crea pruebas creíbles sobre el rendimiento, el daño, el mal uso, la seguridad, la privacidad y la incertidumbre.

6.1 Plan de medición

- Traduce cada riesgo importante en una afirmación comprobable y un umbral de aceptación antes de ver el resultado.
- Utiliza datos de evaluación representativos, protegidos y versionados con procedencia documentada, exclusiones y lagunas conocidas.
- Evalúa casos normales, de borde, de subgrupo, multilingües, de accesibilidad, adversariales, de alto impacto y de fallo seguro.
- Separar los datos de desarrollo, validación y aceptación final cuando sea posible para reducir el sobreajuste.
- Mide tanto beneficios como perjuicios; los promedios pueden ocultar fallos graves en un subgrupo o evento raro.
- Registrar la versión del modelo/sistema, el prompt, las herramientas, los datos, el entorno, el puntuador, la rúbrica humana, la muestra, la aleatoriedad, el coste, el resultado, la confianza y las limitaciones.
- Utiliza la revisión independiente cuando el impacto, la incertidumbre, el conflicto de intereses o la confianza externa sean altos.

Medida	Pregunta	Ejemplo de evidencia
Calidad de la tarea	¿Cumple la tarea prevista?	Precisión, anclaje, gravedad del error, valoración humana
Seguridad	¿Evita daños inaceptables?	Pruebas de escenario, rechazos, escalada, análisis de riesgos
Seguridad	¿Puede un atacante manipular o extraer valor?	Modelo de amenaza, pruebas de inyección, pruebas de abuso de herramientas, informe del equipo rojo
Justicia	¿Los errores o el tratamiento varían de forma significativa?	Resultados de subgrupos, revisión interseccional, análisis causal/contexto
Privacidad	¿Se pueden exponer, inferir, retener o mal utilizar los datos?	DPIA, pruebas de fugas, pruebas de acceso/retención/eliminación
Resiliencia	¿Falla de forma segura durante el cambio o se apaga de forma segura?	Pruebas de carga, deriva, dependencia, rollback, recuperación

7. GESTIONAR: Tratamiento, Despliegue y Mejora

MANAGE convierte el riesgo medido en una decisión propia, un tratamiento, condiciones de despliegue, monitorización y mejora.

Tratamiento	Cuando es útil	Registro obligatorio
Evita	El uso está prohibido o el riesgo no puede justificarse	Decisión, alcance afectado, alternativas, aplicación
Reducir	Los controles pueden reducir la probabilidad o el impacto	Control, propietario, fecha de vencimiento, riesgo residual, prueba
Transferencia/compartir	El contrato o el seguro asignan parte de la consecuencia	Asignación exacta, exclusiones, dependencia, riesgo restante
Aceptar	El riesgo residual está dentro de la autoridad y el apetito	Justificación, evidencia, aprobación, condiciones, caducidad, seguimiento
Piloto	La incertidumbre puede reducirse de forma segura	Limitada gente/datos/autoridad/tiempo, regla de parada, medición, salida

7.1 Puerta de despliegue

- Las revisiones requeridas están completas y los hallazgos no resueltos se encuentran dentro de la tolerancia autorizada.
- Se cumplen los umbrales de aceptación en el sistema completo similar a la producción, no solo en el modelo base.
- Los usuarios comprenden el propósito, los límites, los usos prohibidos, las obligaciones de verificación y la escalada.
- Los revisores humanos tienen tiempo, habilidad, información, autoridad y una anulación útil.
- Los controles de seguridad, privacidad, proveedores, registro, incidentes, continuidad, rollback, registro y eliminación están listos.
- La monitorización incluye propietarios, umbrales, alertas, manuales de respuesta, desencadenantes de cambio y criterios de jubilación.

8. Perfil de IA generativa del NIST

NIST AI 600-1 adapta el RMF de IA a riesgos especialmente importantes para la IA generativa.

Tema de riesgo	Significado práctico	Ejemplo de tratamiento
Confabulación	La salida plausible puede ser falsa	Fundamento, citas, verificación, incertidumbre, uso limitado de decisiones
Contenido peligroso o odioso	La producción puede facilitar daños o abusos	Usar límites, clasificadores, políticas, revisión, monitorización, informes
Privacidad de datos	La información sensible puede entrar o salir del sistema	Minimización, redacción, acceso, retención, eliminación y pruebas de fuga
Integridad de la información	El contenido sintético puede engañar o distorsionar los ecosistemas	Divulgación, procedencia, verificación, límites de tasa, respuesta
Seguridad de la información	Los atacantes pueden inyectarse, robar, evadir o explotar	Modelado de amenazas, aislamiento, privilegio mínimo, gestión segura de salidas
Propiedad intelectual	La formación, la entrada o la salida pueden generar problemas de derechos	Procedencia, términos, licencias, revisión, registros, proceso de disputa
Impactos medioambientales	La formación y el uso consumen recursos	Medir energía/calcular dónde es material; establecer controles de eficiencia y uso
Configuración humano-IA	El sesgo de automatización o la dependencia emocional pueden causar daño	Diseño de interfaces, alfabetización, revisión humana, escalada, salvaguardas de bienestar
Cadena de valor	El riesgo viaja a través de datos, modelo, plataforma, integrador y usuario	Mapeado de proveedores, contratos, pruebas, aviso de cambio, incidentes compartidos

Uso del perfil: Selecciona los riesgos y las acciones relevantes para el caso de uso real. No afirmes que todos los riesgos de la IA generativa están resueltos solo porque un proveedor de propósito general ofrece salvaguardas.

9. ISO/IEC 42001 e ISO/IEC 23894

ISO/IEC 42001 proporciona un sistema de gestión de IA; ISO/IEC 23894 proporciona orientación para la gestión de riesgos en IA.

Elemento del sistema de gestión	Producción práctica
Contexto	Partes interesadas, obligaciones, alcance de la IA, procesos, dependencias
Liderazgo	Política, responsabilidad, roles, recursos, dirección de riesgos
Planificación	Riesgos, oportunidades, objetivos, acciones, planificación del cambio
Apoyo	Competencia, conciencia, comunicación, información documentada
Funcionamiento	Proceso de riesgo de IA, evaluación de impacto, controles del ciclo de vida, proveedores
Evaluación del desempeño	Monitorización, medición, auditoría interna, revisión de gestión
Mejora	No conformidad, acciones correctivas, mejora continua

9.1 Certificaciones y advertencias sobre derechos de autor

- Utiliza una copia autorizada de las normas ISO; este manual no reproduce su texto de requisitos ni de control.
- Define con precisión el alcance del sistema de gestión de IA: organización, productos, servicios, ubicaciones, tecnologías y exclusiones.
- Un certificado incluye únicamente la organización nombrada, el alcance, la norma, las fechas y el estado de certificación.
- La certificación no demuestra que todos los resultados de IA sean precisos, justos, seguros o legales.
- Mapea los procesos existentes de seguridad, privacidad, calidad, riesgo, proveedores y auditoría para evitar el papeleo paralelo.

10. Inventario, casos de uso y ciclo de vida de la IA

Un inventario preciso y un ciclo de vida controlado son la base de la gobernanza.



A use-case gate matches oversight and evidence to risk

Figura 5. Puerta de casos de uso de IA

Campo de inventario	Qué grabar
Identidad	Nombre del sistema/caso de uso, ID, propietario, patrocinador, equipo, estado
Propósito	Uso previsto, usuarios, personas afectadas, decisiones, beneficio, uso prohibido
Tecnología	Modelo/proveedor/versión, prompts, RAG, agentes, herramientas, APIs, hosting
Datos	Fuentes, propietarios, sensibilidad, derechos, ubicación, retención, uso de la formación
Impacto	Nivel de riesgo, daños, leyes, contratos, evaluaciones, supervisión humana
Evidencia	Evaluación, seguridad, privacidad, proveedor, accesibilidad, aprobación
Operaciones	Monitorización, incidentes, cambios, dependencias, recuperación, jubilación

10.1 Controles del ciclo de vida

- Recepción y cribado antes de la adquisición, experimentación con datos reales o uso público.
- Diseñar mapas de sistemas y datos, evaluaciones de impacto y de amenazas, requisitos, umbrales de aceptación y de retroceso.
- Construye con control de versiones, entornos protegidos, componentes aprobados, linaje, pruebas y revisión.
- Validar el sistema completo de forma lo suficientemente independiente como para evaluar su impacto y su incertidumbre.
- Aprobar con condiciones registradas; desplegar mediante control de cambios; formar a usuarios y revisores.
- Supervisa la calidad, la seguridad, la protección, la privacidad, la equidad, el coste, el uso, los proveedores e incidentes.
- Reevaluar los cambios materiales y retirar de forma segura los accesos, integraciones, datos, artefactos, cuentas y registros.

11. Gobernanza de Datos y Seguridad de los Datos

Los controles de datos determinan qué puede aprender, exponer, reproducir o enfatizar injustamente un sistema de IA.

11.1 Cadena de control de datos

- Propósito y autoridad: por qué se necesita cada fuente y qué derechos, avisos, permisos o licencias permiten su uso.
- Procedencia y linaje: fuente, método de recopilación, fecha, versión, transformaciones, etiquetas, filtros y usos posteriores.
- Calidad y representatividad: integridad, precisión, actualidad, duplicados, desequilibrio, error de etiqueta, sesgo histórico y poblaciones relevantes.
- Seguridad: clasificación, privilegio mínimo, separación, cifrado, secretos, transferencia segura, monitorización, copia de seguridad y eliminación.
- Privacidad: minimización, seudonimización/desidentificación, riesgo de reidentificación, derechos del sujeto de datos, retención, transferencia y técnicas para mejorarla.
- Defensa contra el envenenamiento: fuentes confiables, controles de contribuyentes, validación, revisión de anomalías, conjuntos de datos firmados/versionados, cuarentena y retroceso.
- Protección de evaluación: evitar fugas en el conjunto de pruebas y preservar un conjunto de aceptación final controlado.

Evidencia	Detalle mínimo
Tarjeta de conjunto de datos	Propósito, origen, personas/poblaciones, colección, campos, etiquetas, exclusiones, límites, licencia
Historial de linaje	Transformaciones de código a funcionalidad, código/versión, propietario, aprobaciones, fechas
Informe de calidad	Normas, población, excepciones, análisis de subgrupos, correcciones, limitaciones
Informe de acceso	Usuarios/servicios, roles, subvenciones, reseñas, eliminaciones, actividad privilegiada
Prueba de delección	Solicitud, sistemas/copias/índices/copias de seguridad, método, resultado, límites residuales

12. Gobernanza de modelos y riesgo de modelo

La gobernanza del modelo controla la selección, documentación, validación, cambio, despliegue y retirada.

Artefacto	Propósito
Tarjeta modelo/sistema	Uso previsto, uso prohibido, arquitectura, datos, rendimiento, limitaciones, ética/seguridad/protección
Registro de versiones	Modelo, pesos, liberación del proveedor, configuración, prompt, adaptadores, herramientas, código, entorno
Informe de validación	Independencia, métodos, datos, umbrales, resultados, fallos, limitaciones, decisión
Nivel de riesgo	Factores de impacto, revisiones requeridas, autoridad de decisión, supervisión
Récord de cambios	Razón, componentes afectados, alcance de regresión, aprobación, despliegue, retroceso
Historial de retirada	Reemplazo, usuarios, integraciones, acceso, artefactos, datos, retención, eliminación, tareas residuales

12.1 Preguntas de validación

- ¿Se utiliza dentro de las condiciones demostradas y aprobadas del modelo?
- ¿Son relevantes los datos y las poblaciones de evaluación para la producción?
- ¿Están los umbrales vinculados al daño empresarial en lugar de limitarse a promedios técnicos?
- ¿La aplicación completa añade indicaciones, recuperación, herramientas, postprocesamiento o comportamiento humano que cambie el riesgo?
- ¿Son visibles la incertidumbre y las limitaciones para los responsables de la toma de decisiones y los usuarios?
- ¿Se puede restaurar una versión anterior y rastrear las decisiones dependientes hasta la versión activa?

13. Modelos de Fundación y Terceros

Un proveedor de modelo de cimentación suministra una capa; la organización que despliega sigue siendo propietaria de su uso, integraciones, datos y efectos.

Pruebas del proveedor	Pregunta de repaso
Documentación del sistema/modelo	Modelo/versión exacta, uso previsto/prohibido, capacidades, límites, evaluación
Garantía de seguridad	Alcance, periodo, pruebas, vulnerabilidades, proceso de incidentes, aislamiento de inquilinos
Términos de datos	Uso de prompt/subida/salida/registro/retroalimentación, entrenamiento, retención, eliminación, ubicación, subprocesadores
Gestión del cambio	Aviso, fijación de versión, deprecación, evidencia de regresión, retroceso
Disponibilidad/resiliencia	Dependencias, límites, soporte, recuperación, continuidad, exportación
Legal/PI	Roles, licencias, indemnización, restricciones, transparencia, apoyo regulatorio
Auditoría/pruebas	Informes, registros, configuración del cliente, acceso, incidentes y pruebas de eliminación
Salida	Exportación, migración, cierre de cuentas, eliminación verificada de datos/modelos/configuración

13.1 Concentración y riesgo en la cadena de valor

- Modelo cartográfico, nube, datos, etiquetado, incrustaciones, base de datos vectorial, orquestación, herramientas, moderación de contenido, monitorización y proveedores de servicios humanos.
- Identifica las dependencias comunes que podrían fallar o cambiar simultáneamente.
- Pon a prueba la responsabilidad contractual frente a la arquitectura técnica.
- Mantener alternativas o un cierre controlado cuando el impacto empresarial lo justifique.
- Reevaluar los cambios de proveedores, los nuevos términos de entrenamiento, la retirada de modelos, las adquisiciones, los incidentes, las sanciones y los cambios en los subprocesadores.

14. Modelado de amenazas de seguridad por IA

El modelado de amenazas identifica activos, límites de confianza, atacantes, rutas de abuso, controles, detecciones y recuperación segura.

14.1 Método de modelos de amenaza

- Dibuja usuarios, administradores, servicios, endpoints de modelos, almacenes de datos, índices, prompts, herramientas, redes, registros, proveedores y revisores humanos.
- Marca activos: datos sensibles, pesos de modelos, indicaciones del sistema, credenciales, decisiones, dinero, cuentas, reputación y seguridad.
- Marca límites de confianza y cada lugar donde el contenido no confiable puede convertirse en instrucciones o acciones.
- Describe los actores de amenaza, acceso, objetivos, condiciones previas, ruta de ataque, impacto en el negocio, evidencia y recuperación.
- Mapear técnicas relevantes de MITRE ATLAS y OWASP, pero añadir un uso indebido específico de dominio y amenazas ordinarias a la aplicación.
- Elige controles preventivos, detectivescos, responsivos y de recuperación; Prueba combinaciones y bypasses.
- Actualiza después de que cambie el modelo, dato, prompt, herramienta, proveedor, permiso, interfaz o uso.

Superficie de amenaza	Ejemplos
Entrada	Inyección directa de prompt, archivos maliciosos, texto oculto, instrucciones de imagen/audio
Contexto	Documentos RAG envenenados, recuperación entre inquilinos, fuentes obsoletas o no autorizadas
Modelo	Extracción, inversión, evasión, envenenamiento, capacidad insegura, denegación de servicio
Producción	XSS, SQL/inyección de comandos, código inseguro, consejos dañinos, afirmaciones falsas
Herramientas/agentes	Abuso de privilegio, agente confundido, fraude en transacciones, bucles, movimiento lateral
Operaciones	Registros débiles, uso de sombras, filtraciones de llaves, actualizaciones inseguras, mala reversión de incidentes

15. Top 10 OWASP para solicitudes LLM 2025

La lista OWASP 2025 es un punto de partida práctico para la seguridad de aplicaciones de IA generativa.

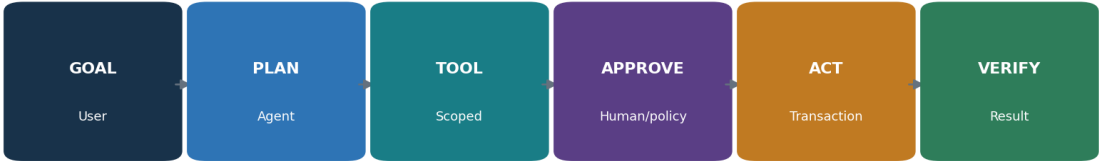
ID / riesgo	¿Qué puede pasar?	Protecciones del núcleo
LLM01 — Inyección de prompt	Las instrucciones no confiables cambian el comportamiento del modelo o alcanzan herramientas conectadas.	Zonas de confianza separadas; restringir herramientas; filtrar contexto; validar acciones; Prueba la inyección directa e indirecta.
LLM02 — Divulgación de Información Sensible	Prompts, salidas, registros, datos de entrenamiento o conectores revelan información protegida.	Minimizar datos; clasificar; redactar; acceso al control; retención de fijas; pruebas de fugas; Monitor.
LLM03 — Cadena de suministro	Modelos, datos, paquetes, adaptadores, servicios o artefactos están comprometidos o no son confiables.	Aprobar fuentes; Verifica procedencia, firmas, hashes, licencias, vulnerabilidades y avisos de cambio.
LLM04 — Intoxicación de datos y modelos	Los datos manipulados o los componentes del modelo generan comportamientos ocultos o inseguros.	Proteger el linaje; validar fuentes; aislar las contribuciones; Haz pruebas de anomalías y de comportamiento.
LLM05 — Manejo incorrecto de la salida	Los sistemas posteriores confían en la salida del modelo como código seguro, contenido o comandos.	Trata la salida como no confiable; validar, codificar, parametrizar, sandboxear y autorizar.
LLM06 — Agencia excesiva	Un sistema de IA tiene más herramientas, permisos, autonomía o tiempo de los necesarios.	Menor privilegio; herramientas estrechas; límites; aprobaciones; límites de transacción; interruptor de apagado; Auditoría.
LLM07 — Fuga de prompts del sistema	Las instrucciones ocultas o secretos se exponen o se utilizan como límite de seguridad.	Guarda secretos fuera de los prompts; hacer cumplir controles externamente; pruebas de fugas; Limita el contexto sensible.
LLM08 — Debilidades del vector y la incrustación	Los índices o incrustaciones permiten la recuperación, envenenamiento, mezcla o inferencia no autorizada.	Aislamiento de inquilinos; ACLs fuente; filtrado de metadatos; revisión de ingestiones; pruebas de recuperación; Eliminación.
LLM09 — Desinformación	Un resultado seguro pero incorrecto puede llevar a decisiones o acciones perjudiciales.	Reclamaciones de terreno; citar fuentes; definir incertidumbre; reseña humana; evaluación fáctica; fallo seguro.
LLM10 — Consumo ilimitado	Las entradas, bucles, salidas o llamadas de herramientas agotan dinero, capacidad de cómputo o de servicio.	Límites de tasa, token, tiempo, recursión, gasto y concurrencia; alertas; cuotas; Interruptores automáticos.

15.1 Cómo utiliza un analista la lista

- Confirma la versión y la arquitectura de la aplicación; el modelo base, por sí solo, no es el objetivo de la evaluación.
- Mapear cada riesgo aplicable a componentes, escenarios de amenaza, controles, pruebas, casos de prueba, propietario y riesgo residual.
- Controles de prueba en conjunto: los filtros pueden omitirse y el comportamiento del modelo es probabilístico.
- Validar fallos seguros, mensajes de usuario, detección, respuesta, retroceso y repuebas.
- No etiquetes una aplicación como 'compatible con OWASP'; el Top 10 de OWASP es una guía de concienciación y de pruebas, no un estándar de certificación.

16. Seguridad de IA Agentica

Los sistemas agenticos añaden planificación, memoria, selección de herramientas, delegación, persistencia y autoridad en el mundo real.



Agent safety depends on constrained authority and verified actions

Figura 6. Bucle de acción del agente restringido

Tema de riesgo agente	Ejemplo	Control
Manipulación de objetivos	El contenido no confiable cambia el objetivo	Canal de objetivos confiable, jerarquía de instrucciones, separación de contexto, confirmación
Mal uso de herramientas	El agente llama de forma insegura al correo electrónico, código, pago, administración o herramienta de base de datos	Lista de permisos, esquemas, identidad restringida, aplicación de políticas, sandbox
Autonomía excesiva	El agente actúa sin una revisión significativa	Aprobaciones basadas en riesgos, vista previa de transacciones, control de dos personas, cambio de parada
Envenenamiento de la memoria	El mal contenido persiste e influye en el trabajo futuro	Fuente de confianza, memoria con alcance, validación, expiración, revisión, eliminación
Fideicomiso agente a agente	Un agente trata la salida de otro como autoridad	Identidad mutua, procedencia, contratos, validación, privilegio mínimo
Comportamiento de fuga	Los bucles consumen tiempo, dinero, llamadas o causan efectos repetidos	Límites de pasos/tiempo/coste, idempotencia, controles de velocidad, interruptor automático
Brecha de responsabilidad	Nadie posee una cadena de decisiones automáticas	Propietario, rastreo, recepción de acción, escalada, retroceso, revisión de incidentes

Fuente actual: OWASP publicó su Top 10 revisado por pares para Aplicaciones Agenticas para 2026 el 9 de diciembre de 2025. Utiliza el documento oficial para conocer sus nombres exactos de riesgos y detalles; aplícalo con la seguridad ordinaria de aplicaciones, identidad, API, datos y transacciones.

17. Seguridad de Generación Aumentada por Recuperación

RAG puede mejorar el grounding, pero añade riesgos de ingestión, indexación, recuperación, autorización, cita y eliminación.



RAG adds trust boundaries at ingestion, storage, retrieval, and generation

Figura 7. Límites de fideicomiso en RAG

Controles RAG 17.1

- Aprobar las fuentes, los propietarios, los derechos, la frescura, la sensibilidad, los usuarios permitidos y el método de ingestión.
- Escanear archivos y contenido; detectar instrucciones ocultas; cuarentena y revisar contribuciones no confiables.
- Conserva en los metadatos la identidad de la fuente, el inquilino, la clasificación, la ACL, la versión, la fecha y el estado de eliminación.
- Hacer cumplir la autorización antes de la recuperación y, de nuevo, antes de la visualización; no te fíes solo de la similitud.
- Inquilinos y dominios de seguridad separados en almacenamiento, claves, índices, caché, registros y evaluación.
- Envenenamiento por pruebas, inyección indirecta, recuperación no autorizada, filtración entre inquilinos, contenido obsoleto, precisión de las citas y eliminación.
- Exigir respuestas para mostrar citas útiles e incertidumbre; Verifica las afirmaciones de alto impacto frente a fuentes autorizadas.
- Propaga la eliminación o corrección de fuentes a fragmentos, vectores, cachés, almacenes derivados y conjuntos de datos de monitorización.

18. Seguridad de Prompts, Interfaz y Salida

Los prompts y salidas son datos de la aplicación, no límites de control fiables.

Capa	Ejemplos de control
Interfaz de usuario	Propósito, aviso, uso prohibido, deber de verificación, ejemplos seguros, comentarios, apelación
Entrada	Límites de tamaño/tipo, escaneo de malware, normalización de codificación, clasificación, redacción, detección de abusos
Instrucciones	Plantillas versionadas, separación de datos/instrucciones, secretos mínimos, aprobación, pruebas
Llamada de modelo	Modelo/versión aprobada, parámetros, límites de tiempo/token/tasa, credenciales protegidas
Producción	Esquema, lista de permisos, codificación, parametrización, cita, revisión de seguridad, confianza/incertidumbre
Uso aguas abajo	Trátate como si no fueras de fiar; aprobación humana o de política; sandbox; validación de transacciones; Retroceso
Troncos	Rastrea IDs y decisiones minimizando, accediendo, retención, integridad y privacidad

18.1 Ejemplos de manejo de salida

- Nunca coloques la salida del modelo directamente en un shell, consulta SQL, DOM del navegador, plantilla, política de acceso o ruta de código de producción sin una validación específica de su propósito.
- Utiliza esquemas estructurados, pero sigue validando tipos, longitudes, valores, autorizaciones y reglas de negocio fuera del modelo.
- Separa la generación de contenido del permiso de actuar. Una respuesta fluida no es prueba de autoridad ni de verdad.
- Rechazo y error de diseño que no revelan secretos y redirigen a los usuarios a alternativas seguras.

19. Identidad, herramientas, APIs y MCP

Los controles de identidad y herramientas determinan la diferencia entre una sugerencia de IA y un evento causado por la IA.

Control	Pregunta sobre la implementación
Identidad humana	¿El usuario está fuertemente autenticado y autorizado para los datos y acciones solicitados?
Identidad de carga de trabajo	¿Cada agente/servicio tiene una identidad única, de corta duración y con un alcance limitado?
Delegación	¿Puede el sistema demostrar quién delegó qué autoridad, para qué recurso, propósito y tiempo?
Lista de herramientas	¿Se permiten explícitamente herramientas, métodos, parámetros, destinos y clases de datos?
Control de transacciones	¿Se aplican los límites de cantidad, volumen, receptor, entorno y acciones irreversibles fuera del modelo?
Aprobación	¿El revisor ve exactamente la acción propuesta, el contexto material, el riesgo y el cambio?
Auditoría	¿Se puede reconstruir cada objetivo, contexto, decisión del modelo, llamada de herramienta, aprobación, resultado y retroceso?

19.1 Seguridad MCP

- El Protocolo de Contexto de Modelo (MCP) conecta aplicaciones de IA con herramientas y datos a través de interfaces estandarizadas; No hace que un servidor o herramienta sea de fiar.
- Servidores de inventario, propietarios, código/fuente, transporte, autenticación, permisos, herramientas, esquemas, datos, destinos de red, registros y ruta de actualización.
- Utiliza registros aprobados, paquetes verificados, versiones fijadas, ejecución restringida, controles de salida, aislamiento secreto y credenciales de privilegio menor.
- Trata las descripciones de herramientas, recursos, prompts y contenido devuelto como potencialmente poco confiables y capaces de influir en el modelo.
- Requiere autorización en el servicio real de datos/acciones, no solo en la capa conversacional.
- Prueba el comportamiento malicioso de los servidores, la confusión de nombres de herramientas, la inyección de parámetros, el flujo de datos entre servidores, los permisos excesivos y las actualizaciones inseguras.

20. Privacidad, Propiedad Intelectual y Registros

Los flujos de datos de la IA plantean preguntas sobre la privacidad, la confidencialidad, la propiedad intelectual, el registro y la divulgación.

20.1 Privacidad y evaluación de registros

- Identificar personas, categorías de datos, sensibilidad, fuente, propósito, autoridad/base legal, avisos, elecciones, derechos y grupos vulnerables.
- Prompts de mapas, subidas, salidas, incrustaciones, ajustes finos, registros, retroalimentación, revisión humana, uso de formación, proveedores, subprocesadores, ubicaciones y transferencias.
- Minimizar la recopilación y el contexto; utilizar redacción, seudonimización, recuperación privada, procesamiento local o datos sintéticos cuando corresponda.
- Establecer la retención y la eliminación por tipo de dato y por copia del sistema; los derechos de prueba y de eliminación a través de proveedores, índices, registros, copias de seguridad y datos derivados.
- Evalúa la memorización, la inferencia, la reidentificación, la predicción de atributos, la inferencia de pertenencia y la filtración entre usuarios.
- Conserva los registros necesarios para decisiones, avisos, consentimiento/autoridad, versiones, aprobaciones, incidentes, disputas y responsabilidad, sin conservarlos indefinidamente.

20.2 Propiedad intelectual

- Confirmar los derechos y las licencias para entrenamiento, ajuste, evaluación, recuperación, prompts, medios, código y salidas.
- Revisa los términos del proveedor sobre propiedad, uso de la formación, confidencialidad, indemnización, restricciones y exclusiones de la compañía.
- Utiliza la procedencia y las credenciales de contenido cuando sea apropiado; conserva las citas de las fuentes y los registros de las contribuciones humanas.
- Filtrar los resultados de alto riesgo para material protegido por derechos de autor, marcas registradas, información confidencial, obligaciones de licencia de código abierto y derechos de publicidad y de personalidad.
- Escalar las cuestiones legales; las herramientas de similitud técnica no determinan la infracción.

21. Equidad, transparencia, explicabilidad y supervisión humana

El uso responsable requiere examinar los efectos desiguales, las explicaciones significativas y la verdadera autoridad humana.

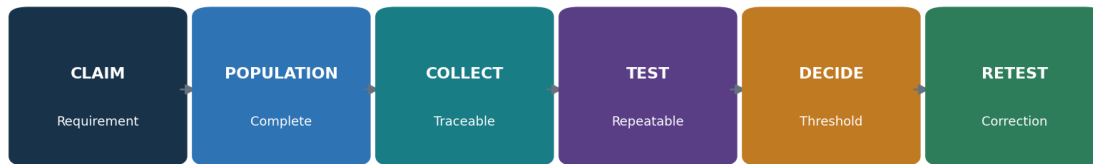
Tema	Prueba práctica
Justicia	Definir el daño y los grupos relevantes; comparar tasas y gravedad; Examina causas, proxies, historia y alternativas
Transparencia	Dile a las personas adecuadas que se utiliza la IA, su propósito, su función, sus límites, datos y cómo obtener ayuda
Explicabilidad	Proporcionar razones útiles a la persona afectada, operador, revisor, auditor o promotor
Supervisión humana	Tiempo del revisor de pruebas, competencia, información, independencia, autoridad, anulación y escalada
Contestabilidad	Proporcionar una forma útil de cuestionar, corregir, apelar y obtener una revisión humana
Accesibilidad	Prueba idiomas, discapacidades, alfabetización, dispositivos y tecnología de asistencia en el flujo de trabajo real

21.1 Evitar errores comunes

- Una métrica de equidad no constituye una conclusión moral ni legal; distintos daños pueden requerir medidas distintas.
- Eliminar un atributo protegido no elimina los proxies ni los patrones históricos.
- Una explicación técnicamente detallada, pero inutilizable para la persona afectada, no tiene sentido.
- Un clic humano no es supervisión si el revisor no detecta errores, está sobrecargado o no puede discrepar.
- Documentos de compensaciones, voces afectadas, alternativas rechazadas, incertidumbre residual y autoridad de decisión.

22. Evaluación, Selección en Equipo Rojo y Aceptación

La evaluación demuestra las reclamaciones definidas solo cuando el sistema, los datos, los métodos, los umbrales y las limitaciones son rastreables.



Assurance joins governance claims to reproducible evidence

Figura 8. Evaluación y cadena de evidencia

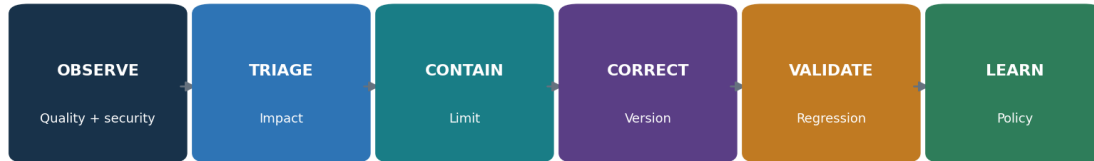
Tipo de prueba	Ejemplos
Funcional	Finalización de tareas, precisión, relevancia, fundamento, citación, formato
Seguridad	Contenido dañino, consejos inseguros, escalada, rechazo, usuarios vulnerables
Seguridad	Inyección, extracción, intoxicación, abuso de herramientas, inyección de salida, denegación de servicio
Privacidad	Filtración de PII, memorización, inferencia, recuperación no autorizada, eliminación
Equidad/accesibilidad	Errores de subgrupo, idioma/dialecto, discapacidad, efectos proxy, usabilidad
Robustez	Ruido, paráfrasis, entrada adversarial, contexto largo, fallo de dependencia, deriva
Operativo	Latencia, capacidad, límites de tasa/coste, monitorización, conmutación por error, rollback, respuesta a incidentes

22.1 Reglas de enfrentamiento del equipo rojo

- Autorización escrita, objetivo nombrado, entorno, tiempo, personas, acciones prohibidas, datos, presupuesto, tarifa y condiciones de parada.
- Datos sintéticos o aprobados para pruebas; no hay contenido dañino incontrolado, segmentación de personas reales, escaneo público ni pruebas de terceros.
- Almacenamiento seguro de prompts, salidas, vulnerabilidades, credenciales e información personal.
- Camino inmediato para hallazgos graves, exposición accidental, inestabilidad del sistema o preocupaciones de seguridad.
- Reproducción, justificación de la severidad, propietario, corrección, prueba de regresión y evidencia de cierre.

23. Supervisión, Incidentes, Cambio y Jubilación

El riesgo de la IA cambia cuando cambian los datos, los modelos, las indicaciones, las herramientas, los usuarios, los proveedores o el mundo exterior.



Monitoring must lead to human decisions and controlled change

Figura 9. Bucle de monitorización e incidentes

Señal	Disparador de respuesta de ejemplo
Calidad	La tasa de error severo o puesta a tierra queda por debajo del umbral aprobado
Seguridad	Salida dañina confirmada, rechazo de bypass o casi impacto de alto impacto
Seguridad	Éxito de inyección, llamada no autorizada a la herramienta, fuga, abuso o evento de credencial
Justicia	Cambio de subgrupo material, patrón de quejas o población recién afectada
Privacidad	Retención inesperada, divulgación, inferencia, fallo de derechos o cambio en el uso del proveedor
Operaciones	Pico de coste/latencia, interrupción de dependencia, bucle descontrolado, fallo de capacidad
Cambio	Nuevo modelo, prompt, dato, herramienta, permiso, proveedor, geografía, uso o ley

23.1 Respuesta a incidentes de IA

- Detectar y preservar prompts, contexto, recuperación, modelo/versión, configuración, herramientas, identidades, aprobaciones, salidas, acciones posteriores y registros.
- Proteger primero a las personas afectadas; detener o limitar el sistema, las herramientas, los datos, los usuarios, las transacciones o las salidas bajo autoridad aprobada.
- Abarca toda la cadena e identifica decisiones o contenidos repetidos que requieran corrección, notificación, reversión o revisión humana.
- Coordina la seguridad, la protección, la privacidad, el área legal, las comunicaciones, los proveedores, el negocio y la respuesta de dominio.
- Corregir mediante versiones confiables; realizar pruebas de regresión; desplegarse gradualmente; observar la recurrencia.
- Registrar las lecciones aprendidas, la responsabilidad, la reparación, los cambios en el control, la reprobación de riesgos y las divulgaciones requeridas por ley o contrato.

24. Aseguramiento, evidencia, pruebas y métricas

La garantía conecta el requisito de completar el alcance, las pruebas fiables, una prueba repetible, una conclusión y una nueva prueba.

24.1 Método de prueba de control

- Indica el criterio exacto, la fuente/versión, el sistema/uso/versión, el periodo, el propietario, el riesgo y el comportamiento esperado.
- Identifica poblaciones completas: casos de uso, modelos, usuarios, decisiones, prompts, herramientas, incidentes, cambios, proveedores o casos de evaluación.
- Concilia el inventario con fuentes independientes, como la facturación de API, el código, el registro de modelos, la identidad, las adquisiciones, la red o los registros.
- Recopilar código fuente, consulta, fecha, permisos, configuración, hash/versión, muestra y cadena de custodia; minimizar las pruebas sensibles.
- Diseño y ejecución de pruebas; reproducción de resultados automatizados; validación de excepciones y prevención de controles.
- Escribe la condición, la evidencia, la población, el riesgo, la causa, la acción, el propietario, la fecha, la protección provisional y vuelve a hacer la prueba.

Métrica	Ejemplo de definición
Propiedad de inventario	Sistemas de IA activos con propietario aprobado ÷ sistemas de IA activos
Cobertura de evaluación	Sistemas dentro del alcance con revisión actual de impacto/amenazas/privacidad ÷ sistemas dentro del alcance
Aprobación de la evaluación	Casos requeridos que cumplen los umbrales aprobados ÷ casos requeridos, con vistas de gravedad y subgrupos
Anulación humana	Decisiones elegibles revisadas/anuladas/escaladas con los resultados y la carga de los revisores
Exposición a la seguridad	Hallazgos de seguridad de IA abiertos por gravedad, accesibilidad, antigüedad, propietario y excepción
Rendimiento en incidentes	Detección, contención, corrección, reparación, recurrencia y acciones atrasadas
Garantía del proveedor	Proveedores críticos de IA con revisiones actuales con alcance y carencias cerradas ÷ proveedores críticos

Precaución en el panel de control: Un porcentaje verde puede ocultar sistemas ausentes, pruebas deficientes, fallos graves raros, grupos excluidos, evidencia obsoleta o riesgos aceptados. Siempre muestra población, origen, periodo, umbral, excepciones, incertidumbre y acción.

25. Matriz de controles de IA de CSA v1.1

CSA AICM v1.1 proporciona una matriz de control actual para la gobernanza, la seguridad, la privacidad, las operaciones y la garantía de la IA.

25.1 Uso práctico

- Descarga el artefacto oficial actual de AICM v1.1 y registra su versión, licencia y cualquier guía de implementación utilizada.
- Define la organización, el servicio de IA, la etapa del ciclo de vida, los roles del proveedor y del cliente, la tecnología, los datos, la geografía y el límite de control.
- Adapta la aplicabilidad en lugar de marcar cada objetivo como sí; indica la justificación de los elementos no aplicables.
- Mapea cada objetivo relevante a la política, la arquitectura, el proceso, el propietario, la evidencia, la prueba, el resultado, el hallazgo, la acción y la reprueba.
- Utiliza mapeos de CSA y STAR para materiales de IA como ayudas; verifica el alcance exacto y el nivel de garantía de cualquier reclamación externa.
- No inventes la certificación ni reclames el cumplimiento basándote únicamente en un cuestionario completado.

Tema de control	Ejemplos de evidencia esperada
Gobernanza y rendición de cuentas	Política, roles, inventario, nivelación de riesgos, formación, excepciones, supervisión de IA
Datos y privacidad	Linaje, derechos, clasificación, minimización, calidad, acceso, retención, eliminación
Ciclo de vida modelo/sistema	Requisitos, tarjetas, validación, desarrollo seguro, versiones, aprobaciones, cambios
Seguridad	Modelo de amenaza, identidad, proveedor, pruebas, registro, incidentes, resiliencia
IA responsable	Evaluación de impacto, equidad, transparencia, supervisión humana, quejas/reparación
Garantía	Mapeo de control, poblaciones, evidencia, revisión independiente, hallazgos, métricas, mejora

26. Herramientas de garantía y seguridad de IA de código abierto

Las herramientas de código abierto pueden mejorar la repetibilidad, pero no deciden el cumplimiento, la seguridad, la equidad ni la aceptación empresarial.

Herramienta	Propósito
Garak	Marco de escaneo de vulnerabilidades y sonda de LLM
Promptfoo	Evaluación de prompts, modelos, RAG y red-team
Giskard	Pruebas y escaneo de vulnerabilidades para sistemas ML y LLM
PyRIT	Identificación de riesgos y orquestación de equipos rojos para IA generativa
Inspect AI	Evaluaciones de modelos de IA reproducibles
Caja de herramientas de robustez adversarial	Ataques y defensas adversariales de aprendizaje automático para investigación autorizada
LLM Guard	Escáneres de entrada y salida para aplicaciones LLM
Presidio	Detección y desidentificación de información personal identificable
IA de barreras	Validación estructurada y guardabarreras para las salidas de los modelos
Evaluaciones de OpenAI	Marco de código abierto para la evaluación de modelos y sistemas
Langfuse	Rastreo de LLM de código abierto, gestión de prompts y evaluación
MLflow	Seguimiento de experimentos, registro de modelos, linaje y registros de despliegue
Evidentemente	Calidad de los datos, deriva y monitorización del modelo
Deepchecks	Validación de datos y modelos para aplicaciones de ML y LLM
ModelScan	Escaneo estático de archivos de modelos serializados
GitLeaks	Descubrimiento secreto en el código fuente y la historia
Trivy	Escaneo de vulnerabilidades, secretos, dependencias, imágenes y configuración
MITRE ATLAS	Base de conocimiento de tácticas y técnicas de adversario contra sistemas de IA

Autorización y seguridad: Utiliza herramientas solo contra sistemas, modelos, cuentas, repositorios, datos y proveedores que poseas o que estés expresamente autorizado a probar. Empieza con laboratorios aislados y datos sintéticos. Establece límites de solicitudes, costes, tiempo, contenido y límites de stop. Protege credenciales, prompts, resultados y hallazgos.

26.1 Garak

Propósito: Marco de escaneo de vulnerabilidades y sonda de LLM. Proyecto oficial: [Garak](#)

Inicio rápido seguro: Instalar en un entorno aislado; seleccionar un modelo de laboratorio y un pequeño conjunto de sondas aprobado; proteger los prompts y salidas; validar los resultados manualmente.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.2 Promptfoo

Propósito: Evaluación del prompt, del modelo, del RAG y de la red team. Proyecto oficial: [Promptfoo](#)

Inicio rápido y seguro: crear un pequeño conjunto de pruebas en YAML con el comportamiento esperado; usar datos sintéticos; gestionarlo localmente; gestionar los fallos en las revisiones; añadir la suite al control de versiones y al CI.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.3 Giskard

Propósito: Pruebas y análisis de vulnerabilidades en sistemas de ML y LLM. Proyecto oficial: [Giskard](#)

Inicio rápido y seguro: Conecta solo un modelo de prueba y un conjunto de datos aprobados; realiza escaneos enfocados; revisa las suposiciones y los falsos positivos; conserva el informe y la revisión de remediación.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.4 PyRIT

Propósito: Identificación de riesgos y orquestación de equipos rojos para IA generativa. Proyecto oficial: [PyRIT](#)

Inicio rápido seguro: utiliza un objetivo de laboratorio y reglas de enfrentamiento documentadas; empieza con objetivos inofensivos; peticiones y costes de tope salarial; revisar transcripciones; Nunca pruebes a terceros sin permiso.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.5 Inspeccionar IA

Propósito: Evaluaciones de modelos de IA reproducibles. Proyecto oficial: [Inspect AI](#)

Inicio rápido seguro: Define una tarea, conjunto de datos, solucionador y puntuador; versiones con pin; competir contra un modelo aprobado; conserva registros, configuración, resultados y limitaciones.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.6 Caja de herramientas de robustez adversarial

Propósito: Ataques y defensas adversariales de ML para investigación autorizada. Proyecto oficial: [Caja de herramientas de robustez adversarial](#)

Inicio rápido y seguro: Utiliza un modelo local de juguetes y datos sintéticos; selecciona una sola amenaza; compara los resultados de la línea base y de las defensas; documenta la aplicabilidad y las limitaciones.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.7 LLM Guard

Propósito: Escáneres de entrada y salida para aplicaciones de LLM. Proyecto oficial: [LLM Guard](#)

Inicio rápido y seguro: Prueba los escáneres en indicaciones sintéticas antes de la producción; ajusta los umbrales; mide los casos perdidos y bloqueados; úsalo como una sola capa, no como el único control.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.8 Presidio

Propósito: Detección y desidentificación de información personal identificable. Proyecto oficial: [Presidio](#)

Inicio rápido seguro: Funcionar con muestras sintéticas; configurar reconocedores para los datos y el lenguaje; revisar falsos positivos y fallos; proteger la salida del analizador.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

IA de las barreras de seguridad 26.9

Propósito: Validación estructurada y barreras de seguridad para las salidas de los modelos. Proyecto oficial: [Guardrails AI](#)

Inicio rápido y seguro: Definir un esquema de salida y validadores; evaluar casos válidos, inválidos y adversariales; fallar de forma segura; registrar las decisiones de validación sin exponer contenido sensible.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.10 Evaluaciones de OpenAI

Propósito: Marco de código abierto para la evaluación de modelos y sistemas. Proyecto oficial: [Evaluaciones de OpenAI](#)

Inicio rápido seguro: crea un pequeño conjunto de evaluación privado; define criterios medibles; haz una línea base y un candidato; inspecciona fallos; protege los datos y credenciales de las pruebas.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.11 Langfuse

Propósito: Rastreo de LLM de código abierto, gestión de prompts y evaluación. Proyecto oficial: [Langfuse](#)

Inicio rápido seguro: Autoalojar o configurar un entorno aprobado; redactar campos sensibles; trazar un flujo de trabajo de laboratorio; establecer acceso y retención; construir un panel de control pequeño y de calidad.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.12 MLflow

Propósito: Seguimiento de experimentos, registro de modelos, linaje y registros de despliegue. Proyecto oficial: [MLflow](#)

Inicio rápido seguro: Utiliza un proyecto local; parámetros de registro, referencia de conjuntos de datos, métricas, artefactos, propietario y aprobación; registrar solo un modelo probado; Restringir los cambios en el registro.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.13 Evidentemente

Propósito: calidad de los datos, derivación y monitorización de modelos. Proyecto oficial: [Evidently](#)

Inicio rápido y seguro: crear conjuntos de datos sintéticos de referencia y actuales; elaborar un informe; definir umbrales de acción; investigar la deriva antes de reentrenarlo o retroceder.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.14 Deepchecks

Propósito: Validación de datos y modelos para aplicaciones de ML y LLM. Proyecto oficial: [Deepchecks](#)

Inicio rápido y seguro: ejecutar un conjunto de pruebas seleccionado con datos aprobados; revisar las comprobaciones fallidas y su relevancia; registrar las excepciones; reemisión tras la corrección.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.15 ModelScan

Propósito: Escaneo estático de archivos de modelos serializados. Proyecto oficial: [ModelScan](#)

Inicio rápido seguro: escanear artefactos de modelos descargados en cuarentena; verificar la fuente y el hash; investigar advertencias; Nunca cargues un artefacto no confiable solo para probarlo.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.16 Gitleaks

Propósito: Descubrimiento secreto en el código fuente y la historia. Proyecto oficial: [Gitleaks](#)

Inicio rápido y seguro: escanear un repositorio autorizado; validar los hallazgos; revocar las credenciales de prueba expuestas; retirar la súper de forma segura; prevención de la ADD (prevención de la ADD); reescanear.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.17 Trivy

Propósito: Escaneo de vulnerabilidades, secretos, dependencias, imágenes y configuración. Proyecto oficial: [Trivy](#)

Inicio rápido y seguro: escanear un repositorio o una imagen autorizado por servicios de IA; validar la accesibilidad y el contexto; corregir o aprobar una excepción con plazo; reescanear.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

26.18 MITRE ATLAS

Propósito: Base de conocimiento sobre tácticas y técnicas del adversario contra sistemas de IA.

Proyecto oficial: [MITRE ATLAS](#)

Inicio rápido seguro: Mapear la arquitectura de un laboratorio a técnicas relevantes; seleccionar mitigaciones y detecciones; crear un escenario de mesa; no trates el catálogo como una lista de verificación completa.

Retener: autorización escrita, destino y versión, entorno, datos, identidad/permisos, herramienta/versión/configuración, casos de prueba, umbrales, fecha, registros, resultados, validación por analistas, limitaciones, halling, corrección y reprueba.

27. Manual de Gobernanza de IA para el Gestor

Los gestores crean valor estableciendo derechos de decisión, limitando la autoridad, exigiendo pruebas y deteniendo trabajos inseguros.

Pregunta sobre el entrenador	Respuesta contundente	Bandera roja
¿Por qué usar IA?	Medidas definidas de necesidad, beneficio, alternativa, propietario, éxito y detención	La tecnología busca un problema
¿Quién puede ser dañado?	Personas afectadas, gravedad, probabilidad, voz, reparación	Solo el usuario de pago se considera
¿Qué puede hacer?	Datos documentados, decisiones, herramientas, permisos, límites	Agentes desconocidos, integraciones o uso en sombras
¿Qué prueba la preparación?	Pruebas similares a la producción, umbrales, fallos, desafío independiente	Solo reclamación de demostración o vendedor
¿Dónde está el humano?	Supervisión competente, informada, autorizada y medida	Aprobación simpática
¿Qué cambia el riesgo?	Inventario, monitorización, lista de desencadenantes, regresión, retroceso	Actualizaciones automáticas de modelos sin revisión
¿Quién acepta el riesgo residual?	Autoridad nombrada dentro del apetito, condiciones y caducidad	El promotor asume solo el riesgo empresarial/legal

27.1 Ritmo de funcionamiento

- Semanal: incidentes graves, abuso activo, uso no autorizado de herramientas/datos, hallazgos críticos, cambios de proveedores y excepciones a la barrera de riesgo.
- Mensual: conciliación de inventarios, umbrales de monitorización, quejas, deriva, fallos en evaluaciones, permisos de herramientas, gasto y acciones atrasadas.
- Trimestral: riesgo de cartera, grupos afectados, concentración de proveedores, supervisión humana, temas de red team, cambios legales y candidatos a la jubilación.
- En cada cambio material: remapear el sistema, reevaluar el impacto/amenaza/privacidad, volver a realizar las evaluaciones pertinentes, aprobar, desplegar gradualmente y conservar la evidencia.

27.2 Preguntas que los líderes deben responder

- ¿Qué sistemas de IA podrían afectar materialmente a las personas, el dinero, la seguridad, los derechos, las decisiones reguladas, las operaciones críticas o los datos confidenciales?
- ¿Qué usos están prohibidos aunque técnicamente sean posibles?
- ¿Puede la organización desactivar herramientas, detener decisiones, notificar a la gente, corregir registros y recuperarse de un fallo del modelo o del proveedor?
- ¿Recompensan los incentivos la rapidez o el compromiso a costa de la seguridad y la verdad?
- ¿Pueden los empleados expresar preocupaciones sin represalias, y son visibles para los responsables de la toma de decisiones las preocupaciones no resueltas?

28. Guía de carrera para analista junior de riesgos y seguridad en IA

Los analistas junior aportan valor creando inventarios precisos, mapas del sistema claros, pruebas reproducibles, hallazgos útiles y límites honestos.



Junior analysts become job-ready by producing safe, traceable work

Figura 10. Vía de riesgo y seguridad en IA Junior

28.1 Puestos de nivel inicial

- Gobernanza Junior de IA o Analista Responsable de IA
- Analista de Riesgos de IA / Modelos
- Analista de Seguridad en IA o Analista de Seguridad GenAI
- GRC / Analista de Cumplimiento con enfoque en IA
- Analista de Gobernanza de Datos o Privacidad
- Analista de riesgos de IA de terceros
- Evaluación de IA / Analista de Confianza y Seguridad
- Analista de Garantía de Valores

28.2 Trabajo diario

Descubre casos de uso de IA y concilia inventario entre compras, código, APIs, identidad, red, gastos y entrevistas.

Documenta los flujos de sistema/datos, personas afectadas, límites de uso, proveedores, permisos y supervisión humana.

Map NIST, ISO, OWASP, CSA, requisitos legales, contractuales e internos para controles y pruebas.

Realizar evaluaciones autorizadas y pruebas de seguridad; Validar resultados y proteger las pruebas.

Revisa la documentación del proveedor, los términos, los modelos de tarjetas, los informes de garantía, los incidentes, los cambios y las responsabilidades del cliente.

Redactar los resultados en lenguaje sencillo; asignar acciones; reprobar; Crea métricas con poblaciones y limitaciones conocidas.

Apoya los plazos de los incidentes con IA, la revisión de las decisiones afectadas, las acciones correctivas y las lecciones aprendidas.

28.3 Pruebas de currículum

Sistema de una página y mapa de flujo de datos con límites de confianza.

Inventario de IA y método de tiering de riesgo para una empresa ficticia.

Evaluaciones de impacto, amenazas, privacidad y proveedores.

Plan de evaluación con umbrales de aceptación y resultados reproducibles.

Tres hallazgos con condición, evidencia, riesgo, causa, acción, propietario y reprobación.

Memorándum del gerente explicando la decisión, la salida condicional, el piloto o la decisión de no ir.

Solo capturas de pantalla/configuración limpias; etiqueta claramente el trabajo como ficticio y educativo.

29. Laboratorio ficticio, plan de treinta días y entrevistas

Una aplicación de IA ficticia puede demostrar gobernanza, pruebas, seguridad y comunicación sin poner en riesgo a personas o sistemas reales.

Regla del laboratorio: Utiliza modelos de prueba locales o aprobados, datos sintéticos, cuentas aisladas, presupuestos fijos y autorización por escrito. Nunca pongas a prueba un modelo de servicio público, un empleador, una empresa de entrevistas o un tercero más allá de su programa y permiso publicados.

29.1 Laboratorio de portafolio

- Crea una empresa ficticia de 80 personas que implementa un asistente interno de políticas de RRHH basado en RAG. Puede explicar la política pero no puede tomar decisiones laborales.
- Escribe el propósito, los usos prohibidos, las personas afectadas, el nivel de riesgo, el RACI, el inventario, la elección del modelo/proveedor y la puerta de aprobación.
- Crear documentos de políticas sintéticos que incluyan un archivo malicioso de inyección indirecta; procedencia de los documentos, ACLs, ingestión, retención y eliminación.
- Dibuja límites entre los datos, el modelo, el RAG, la herramienta y la confianza humana, y crea un modelo de amenaza basado en MITRE ATLAS y OWASP.
- Elabora argumentos de evaluación para fundamentos, citas, privacidad, equidad/accesibilidad, inyección rápida, consejos inseguros y uso ilimitado.
- Usa Promptfoo, Garak, Giskard o Inspect AI en una prueba aislada; realiza una actividad de tope salarial; valida manualmente los resultados.
- Recuperación correcta de ACLs, separación de instrucciones, validación de salida, privilegio mínimo, registro, límites y escalado; repetir.
- Redacta un documento de trabajo de garantía, tres conclusiones, una decisión sobre el riesgo residual, un panel de monitorización, un cuadro de incidentes y una lista de verificación para la jubilación.
- Publica solo pruebas sintéticas sanitizadas y explica lo que el laboratorio no ha demostrado.

29.2 Plan de treinta días

Días	Enfoque	Entrega
1–3	Fundamentos de la IA y características fiables	Mapa conceptual y glosario
4–6	NIST AI RMF y gobernanza	RACI, esquema de políticas, inventario
7–9	Mapeo de casos de uso e impacto	Mapa del sistema y evaluación de impacto
10–12	Gobernanza de datos/modelos	Tarjetas de conjunto de datos y modelos
13–15	Amenazas, OWASP, ATLAS	Modelo de amenazas y requisitos de seguridad
16–18	RAG, agentes, identidad, MCP	Límites de confianza y política de herramientas
19–21	Evaluación y selección de equipos rojos	Plan de pruebas, umbrales, resultados
22–24	Privacidad, equidad, transparencia	Tres trabajos de revisión
25–27	Monitorización, incidente, garantía	Panel de control, juegos de mesa, pruebas de control
28–30	Portafolio y entrevistas	Memorándum del gerente y cinco historias STAR

29.3 ¿Qué es el RMF de IA del NIST?

Un marco voluntario para gestionar los riesgos de IA mediante Gobernar, Mapear, Medir y Gestionar. Se centra en los riesgos para las personas, las organizaciones y la sociedad.

29.4 Riesgo de modelo frente a riesgo de sistema

El riesgo del modelo se refiere al comportamiento del modelo; el riesgo del sistema incluye personas, datos, interfaces, herramientas, infraestructura, proveedores, procesos y decisiones del mundo real.

29.5 ¿Qué es la inyección rápida?

El contenido no confiable se interpreta como instrucciones que cambian el comportamiento o acceden a datos y herramientas. Trata el contenido como datos, limita la autoridad, valida las acciones y prueba los bypass.

29.6 ¿Cómo evalúas un LLM?

Definir el uso y los perjuicios, crear casos y umbrales representativos, probar la versión completa del sistema, revisar fallos e incertidumbre, aprobar condiciones y monitorizar los cambios.

29.7 ¿Qué es RAG?

La generación aumentada por recuperación recupera contenido externo y lo entrega a un modelo. Añade fuentes y riesgos, acceso, envenenamiento, inyección, cita, frescura y eliminación.

29.8 ¿Por qué es difícil la supervisión humana?

Un revisor puede carecer de tiempo, información, habilidades, independencia o autoridad, y puede confiar en exceso en la automatización. La supervisión debe diseñarse y comprobarse.

29.9 ¿Qué es un inventario de IA?

Un registro propio de uso, propósito, personas, tecnología, modelos, datos, proveedores, impacto, aprobaciones, controles, monitorización y jubilación.

29.10 ¿Cómo demuestran las herramientas el cumplimiento?

No es así. Las herramientas producen pruebas que un analista debe definir, validar e interpretar según los requisitos y conectarlas con decisiones y remediación.

29.11 ¿Cómo se informa de un hallazgo?

Estado de estado, evidencia/población, requisito, impacto empresarial y de las personas, causa, recomendación, propietario, fecha de parto, protección provisional y reprobación.

29.12 ¿Qué hace a un buen analista junior?

Curiosidad, cuidado en el alcance, respeto por las personas y los datos, pruebas reproducibles, escritura clara, incertidumbre honesta, uso seguro de herramientas y seguimiento de la información.

30. Plantillas, glosario, índice y referencias

Los formularios reutilizables y las fuentes autorizadas ayudan a convertir conceptos en trabajos consistentes.

Inventario de casos de uso de IA 30.1

Campo	Entrada
ID del sistema/uso, estado, propietario, patrocinador	
Propósito, beneficio, usuarios, personas afectadas	
Decisiones/contenido, autonomía, usos prohibidos	
Modelo/proveedor/versión/configuración	
Datos, derechos, sensibilidad, ubicación, retención	
RAG, agentes, herramientas, APIs, MCP	
Nivel de impacto, leyes/contratos, evaluaciones	
Supervisión humana, apelación, reparación	
Evaluación, aprobación, condiciones	
Supervisión, incidentes, cambios, jubilación	

30.2 Evaluación del impacto y riesgo de la IA

Campo	Entrada
Contexto, personas, alternativas, dependencia	
Beneficios y medidas de éxito	
Daños: derechos, seguridad, financieros, sociales, operativos	
Verosimilitud, gravedad, escala, reversibilidad, incertidumbre	
Grupos afectados y accesibilidad	
Limitaciones de datos/modelo/proveedores	
Controles y umbrales de evaluación	
Supervisión humana y disputabilidad	
Riesgo residual y autoridad de decisión	
Revisión de desencadenantes y caducidad	

30.3 Trabajo de evaluación de IA

Campo	Entrada
Reclamación, riesgo, requisito, umbral	
Versiones del sistema/modelo/prompt/herramienta	
Entorno y permisos	
Procedencia y población del conjunto de datos	
Casos, puntuadores, rúbrica humana, muestra	
Aleatoriedad/repeticiones y confianza	
Resultados, fallos, análisis de subgrupos	
Limitaciones y exclusiones conocidas	
Decisión, condiciones, conclusiones	
Corrección y repetición de la prueba de regresión	

30.4 Registro de incidentes y cambios de IA

Campo	Entrada
ID del caso/cambio, propietario, gravedad	

Campo	Entrada
Sistema/versión/personas/decisiones afectadas	
Prompt, contexto, recuperación, herramientas, identidades	
Cronología, preservación de pruebas, proveedor	
Contención y protección de las personas afectadas	
Corrección, reversión, reparación, notificación	
Causas raíz/contribuyentes	
Versión confiable, validación, retroceso	
Reaprobación y seguimiento de riesgos	
Lecciones, acciones, repetición, cierre	

30.5 Glosario

Término	Significado
Agente	Software habilitado por IA que planifica y utiliza herramientas para alcanzar un objetivo.
AI RMF	Marco de Gestión de Riesgos de Inteligencia Artificial del NIST.
AICM	Matriz de controles de IA de la CSA.
Confabulación	Contenido generado plausible pero falso o no soportado.
Incrustación	Representación numérica utilizada para comparar significado o similitud.
Evaluación	Medición estructurada de reclamaciones y riesgos definidos por el sistema.
Modelo de fundación	Un modelo amplio que puede adaptarse a muchas tareas posteriores.
Conexión a la tierra	Grado en que la producción está respaldada por fuentes proporcionadas o autorizadas.
Supervisión humana	Capacidad humana significativa para entender, supervisar, intervenir, anular o detenerse.
Evaluación de impacto	Revisión de los efectos previstos y previsibles sobre personas y organizaciones.
Inferencia	Utilizar un modelo entrenado para producir una predicción o resultado.
MCP	Model Context Protocol, un estándar para conectar aplicaciones de IA con herramientas y datos.
Tarjeta modelo	Documentación estructurada del uso previsto, del rendimiento, de los límites y de otros hechos.
Deriva del modelo	Cambios en el rendimiento o comportamiento a medida que cambian los datos o el contexto.
Inyección rápida	Las instrucciones poco fiables alteran el comportamiento del modelo o de la aplicación.
RAG	Generación aumentada por recuperación.
Equipo rojo	Evaluación autorizada de riesgos y modos de fallo adversarios.
Sistema sociotécnico	La tecnología y las personas, las normas, las instituciones y el contexto que la rodean.
Tarjeta de sistema	Documentación del sistema completo de IA, evaluación, riesgos y límites.
Base de datos vectorial	Servicio de almacenamiento y búsqueda de incrustaciones y metadatos asociados.

30.6 Índice temático

Tema	Capítulo
Agentes/autonomía	16, 19
AICM	25
Garantías/pruebas	22–25
Datos/privacidad	11, 20
Ley de IA de la UE	2
Equidad/supervisión	21
Perfil GenAI	8
Inventario/ciclo de vida	10
ISO 42001 / 23894	9
Entrenador	27
MCP / herramientas	19
Modelos/proveedores	12–13
Monitorización/incidentes	23
NIST AI RMF	3–7
Herramientas de código abierto	26
OWASP / modelo de amenaza	14–16
RAG	17
Pruebas / equipo rojo	6, 22
Analista junior	28–29

30.7 Referencias oficiales

- [Marco de Gestión de Riesgos de IA del NIST](#)
- [NIST AI RMF 1.0 PDF](#)
- [NIST AI RMF Playbook y AIRC](#)
- [Perfil de IA generativa NIST AI 600-1](#)
- [Taxonomía de Aprendizaje Automático Adversarial del NIST](#)
- [ISO/IEC 42001:2023](#)
- [ISO/IEC 23894:2023](#)
- [Página de política de la Ley de IA de la UE](#)
- [Cronología oficial de implementación de la Ley de IA de la UE](#)
- [Top 10 de OWASP para aplicaciones LLM 2025](#)
- [Top 10 de OWASP para aplicaciones de agentes 2026](#)
- [Proyecto de Seguridad OWASP GenAI](#)
- [MITRE ATLAS](#)
- [Recursos de la Matriz de Controles de IA de CSA](#)
- [CSA STAR para IA](#)
- [Principios de IA de la OCDE](#)
- [Recomendación de la UNESCO sobre la ética de la IA](#)
- [Recursos de IA de CISA](#)
- [Inspección del Instituto de Seguridad de IA del Reino Unido](#)

Recordatorio final: la ley, los estándares, las amenazas, el comportamiento de los modelos, los proveedores, los términos, las herramientas y las directrices oficiales de la IA cambian rápidamente. Verifica la fuente actual, la versión del sistema, los hechos y la jurisdicción antes de implementar, evaluar, desplegar o aceptar riesgos.